

MARCO INTEGRATIVO: GQM + PRAGMATIC APLICADO A BSIMM15

Indicadores de Madurez en Seguridad de Software con Trazabilidad Completa

Versión: 1.0

Fecha: Enero 21, 2026

Metodología: Goal-Question-Metric + PRAGMATIC Metametrics

Base de Datos: BSIMM15 (121 organizaciones, 128 actividades)

INTRODUCCIÓN: TRAZABILIDAD Y RIGOR EN MÉTRICAS BSIMM

La Building Security In Maturity Model (BSIMM15) analiza 121 organizaciones globales con 128 actividades de seguridad de software distribuidas en 4 dominios y 12 prácticas. Sin embargo, sin una estructura metodológica clara que conecte **objetivos estratégicos** con **preguntas operacionales** y **métricas técnicas**, los hallazgos quedan flotando sin contexto ni justificación.

Este documento integra dos metodologías complementarias:

1. GQM (Goal-Question-Metric): Asegura trazabilidad desde objetivos de negocio hacia métricas técnicas
2. PRAGMATIC: Garantiza que cada métrica sea prácticamente útil

PARTE I: METODOLOGÍA GQM APLICADA A BSIMM

1.1 Estructura GQM

NIVEL 1: GOAL (Objetivo Estratégico)
↓ "¿Qué queremos lograr?"
NIVEL 2: QUESTIONS (Preguntas Operacionales)
↓ "¿Cómo sabemos que lo logramos?"
NIVEL 3: METRICS (Métricas Técnicas)
↓ "¿Qué podemos medir?"

1.2 Las Tres Dimensiones de BSIMM en GQM

DIMENSIÓN 1: GOVERNANCE (Dominio A)

GOAL A1: Establecer control organizacional sobre iniciativas de seguridad de software

Práctica	Pregunta GQM	Métrica BSIMM
SM (Strategy & Metrics)	¿Existe una estrategia documentada?	% orgs con SSI formal (83%+)
PC (Process Compliance)	¿Se auditan procesos regularmente?	# ciclos auditoria/año
EM (Enforce Metrics)	¿Se miden y reportan controles?	# métricas en dashboard ejecutivo
O (Organization)	¿Hay roles/responsabilidades claras?	RACI documentado (sí/no)

PARTE II: LOS NUEVE CRITERIOS PRAGMATIC

2.1 Definición de PRAGMATIC

Criterio	Significado	Aplicación a BSIMM
P	Predictive	¿Predice la métrica riesgo futuro?
R	Relevant	¿Es relevante a objetivos negocio?
A	Actionable	¿Lleva a acción específica?
G	Genuine	¿Se basa en datos reales (no teóricos)?
M	Meaningful	¿Tiene significado operacional?
A	Accurate	¿Es medible y precisa?
T	Timely	¿Se obtiene en tiempo útil?
I	Independent	¿No depende de otras métricas?
C	Cost-effective	¿Es económicamente viable medir?

2.2 Escala de Evaluación PRAGMATIC

Cada criterio se califica 0-100:

- 0-30: No cumple (rojo)
- 31-60: Cumple parcialmente (amarillo)
- 61-100: Cumple completamente (verde)

Score PRAGMATIC Final: Promedio de 9 criterios (0-100)

PARTE III: MATRIZ GQM + PRAGMATIC PARA BSIMM15

3.1 DOMINIO GOVERNANCE

G1: Crear/Interfaz con Respuesta Incidentes [CMVM1.1] - 91.7% orgs

GOAL (G): Detectar y responder rápidamente a incidentes de seguridad en código

QUESTIONS (Q):

- Q1: ¿Existe proceso formal de incident response para software?
- Q2: ¿Se documenta cada incidente con root cause?
- Q3: ¿Se mide MTTD (Mean Time To Detect) incidentes software?
- Q4: ¿Se rastrea el % de incidentes detectados internamente vs externos?

METRICS (M):

- M1: % orgs con playbook IR documentado
- M2: # incidentes/año en que se identificó root cause
- M3: MTTD promedio (horas)
- M4: % incidentes detectados internamente (target 80%+)
- M5: % cobertura IR en todas las apps críticas

PRAGMATIC EVALUATION:

- P (Predictive): 85 → MTTD predice eficacia detección
- R (Relevant): 95 → Alineado con riesgo software directo
- A (Actionable): 90 → Lleva a mejora proceso/herramientas
- G (Genuine): 92 → Basado en datos 121 orgs BSIMM15
- M (Meaningful): 88 → Impacto directo en riesgo
- A (Accurate): 87 → Medible en logs/SIEM
- T (Timely): 80 → Disponible mensual/trimestral
- I (Independent): 75 → Correlaciona con CR1.4, AA1.1
- C (Cost): 85 → Bajo costo extraer de SIEM existente

PRAGMATIC SCORE: 87/100 ✓ EXCELENTE

G2: Implementar Checkpoints Seguridad [SM1.4] - 90.1% orgs

GOAL (G): Formalizar puntos de control de seguridad en el pipeline de desarrollo

QUESTIONS (Q):

- Q1: ¿Existen checkpoints de seguridad documentados?
- Q2: ¿Se ejecutan automáticamente o requieren aprobación manual?
- Q3: ¿Cuántos hallazgos se bloquean en checkpoint vs pasan a prod?
- Q4: ¿Se mide cobertura de aplicaciones bajo checkpoints?

METRICS (M):

- M1: # checkpoints de seguridad por fase (pre-commit, pre-release, pre-prod)
- M2: % automático vs manual (target 70%+ automático)
- M3: Ratio hallazgos bloqueados/permitidos (target 95%+ bloqueados en crítico)
- M4: % aplicaciones bajo checkpoints (target 100%)
- M5: MTTR promedio para resolver hallazgo en checkpoint (horas)

PRAGMATIC EVALUATION:

- P (Predictive): 93 → Bloqueo directo de código inseguro
- R (Relevant): 96 → Prevención = máximo ROI seguridad
- A (Actionable): 94 → Acción inmediata por desarrollador
- G (Genuine): 90 → Datos de CI/CD pipelines observados
- M (Meaningful): 92 → Impacto prevención directa
- A (Accurate): 91 → Medible en CI/CD logs
- T (Timely): 93 → Real-time durante build
- I (Independent): 70 → Depende de CR1.4, SAST tools
- C (Cost): 88 → Bajo costo (integración herramientas)

PRAGMATIC SCORE: 89/100 ✓ EXCELENTE

3.2 DOMINIO INTELLIGENCE (Risk & Threat Management)

I1: Usar Herramientas Revisión Código Automatizada [CR1.4] - 87.6% orgs

GOAL (G): Automatizar detección de defectos de seguridad en código fuente

QUESTIONS (Q):

- Q1: ¿Se realiza análisis SAST en 100% del código?
- Q2: ¿Se utiliza SCA para dependencias?
- Q3: ¿Se correlacionan hallazgos SAST+SCA?
- Q4: ¿Cuál es la tasa de falsos positivos?
- Q5: ¿Se rastrean hallazgos de SAST a remediación?

METRICS (M):

- M1: % código sujeto a SAST scanning (target 100%)
- M2: % dependencias sujeto a SCA scanning (target 100%)
- M3: # vulnerabilidades detectadas por SAST/año
- M4: % falsos positivos (target <10%)
- M5: MTTR SAST hallazgo crítico (target <30 días)
- M6: # SAST rules customizadas vs default

PRAGMATIC EVALUATION:

- P (Predictive): 94 → Predice vulnerabilidades antes deployment
- R (Relevant): 96 → Core al secure SDLC
- A (Actionable): 92 → Acción directa a developers
- G (Genuine): 94 → Datos de 87.6% orgs
- M (Meaningful): 91 → Impacto prevención código
- A (Accurate): 93 → Medible en SAST reports
- T (Timely): 91 → Disponible durante desarrollo
- I (Independent): 85 → Puede ser independiente si bien correlaciona
- C (Cost): 82 → Herramientas SAST premium son costosas

PRAGMATIC SCORE: 91/100 ✓ EXCELENTE

I2: Realizar Análisis Riesgos Amenazas [AA1.1] - 86% orgs

GOAL (G): Identificar y evaluar amenazas/vulnerabilidades de arquitectura

QUESTIONS (Q):

- Q1: ¿Se realiza threat modeling en diseño?
- Q2: ¿Se documenta superficie de ataque?
- Q3: ¿Se priorizan amenazas por riesgo?
- Q4: ¿Se rastrea evolución de amenazas?

METRICS (M):

- M1: # aplicaciones sujetas a threat modeling (target 100% críticas)
- M2: % surface de ataque documentada
- M3: # amenazas identificadas y priorizadas por CVSS
- M4: % de amenazas con control mitigador
- M5: Frecuencia revisión threat model (recomendado anual)

PRAGMATIC EVALUATION:

- P (Predictive): 88 → Identifica vulnerabilidades arquitectura
- R (Relevant): 87 → Alineado a diseño seguro
- A (Actionable): 85 → Lleva a cambios arquitectura
- G (Genuine): 84 → Basado en análisis real (subjetivo)
- M (Meaningful): 83 → Impacto en diseño
- A (Accurate): 80 → Parcialmente medible (subjetivo)
- T (Timely): 75 → Típicamente 2-4 semanas por threat model
- I (Independent): 70 → Depende de arquitectos, expertise
- C (Cost): 72 → Requiere experts (costoso)

PRAGMATIC SCORE: 81/100 ✓ BUENO

3.3 DOMINIO SSDL TOUCHPOINTS (Testing & Validation)

T1: Realizar Pruebas Dinámicas (Testing) [ST1.1] - 75% orgs

GOAL (G): Validar seguridad en tiempo de ejecución (DAST, fuzz, etc.)

QUESTIONS (Q):

- Q1: ¿Se realiza DAST en aplicaciones web?
- Q2: ¿Se hace fuzzing de APIs?
- Q3: ¿Se rastrea cobertura de testing vs código?
- Q4: ¿Qué % de hallazgos DAST se remedian?

METRICS (M):

- M1: % aplicaciones web sujetas a DAST (target 100%)
- M2: Frecuencia DAST (recomendado: pre-release)
- M3: # vulnerabilidades detectadas por DAST/año
- M4: % de hallazgos DAST remediados en 30 días
- M5: MTTD vulnerabilidad en tiempo de ejecución (horas)

PRAGMATIC EVALUATION:

- P (Predictive): 82 → Detecta vulnerabilidades runtime
- R (Relevant): 85 → Complementa SAST (cobertura completa)
- A (Actionable): 86 → Acción directa a developers
- G (Genuine): 83 → Datos observados en 75% orgs
- M (Meaningful): 80 → Impacto en prevención
- A (Accurate): 84 → Medible pero muchos falsos positivos
- T (Timely): 78 → 1-2 semanas típicamente
- I (Independent): 72 → Complementario a SAST
- C (Cost): 75 → Herramientas DAST moderadamente costosas

PRAGMATIC SCORE: 81/100 ✓ BUENO

T2: Pruebas de Penetración Manual [ST2.1] - ~60% orgs

GOAL (G): Validar seguridad a través de evaluación manual por expertos

QUESTIONS (Q):

- Q1: ¿Se realizan pentests regularmente?
- Q2: ¿Qué % de hallazgos se remedian?
- Q3: ¿Se revalida post-remediación?
- Q4: ¿Se documentan lecciones aprendidas?

METRICS (M):

- M1: Frecuencia pentests (anual mínimo)
- M2: # vulnerabilidades críticas encontradas/año
- M3: % remediadas en SLA (target >80% en 30 días)
- M4: % revalidadas post-fix (target 100%)
- M5: MTTR crítico pentesting (target <30 días)

PRAGMATIC EVALUATION:

- P (Predictive): 85 → Emula ataque real
- R (Relevant): 88 → Valida controles en contexto real
- A (Actionable): 87 → Hallazgos específicos a equipos
- G (Genuine): 82 → Basado en expertise (subjetivo)
- M (Meaningful): 86 → Alto impacto en validación
- A (Accurate): 75 → Subjetividad del pentester
- T (Timely): 60 → 2-4 semanas por pentest
- I (Independent): 65 → Complementario a SAST/DAST
- C (Cost): 60 → Pentesting experto es costoso (€10k-50k)

PRAGMATIC SCORE: 77/100 ✓ **ACEPTABLE** (pero costoso)

3.4 DOMINIO DEPLOYMENT (Ops, Deployment, Management)

D1: Automatizar Verificación Infraestructura [DM1.1] - ~70% orgs

GOAL (G): Automatizar validación de configuración de infraestructura

QUESTIONS (Q):

- Q1: ¿Se automatizan configuración security checks?
- Q2: ¿Se rastrean desvíos (drift) de baseline?
- Q3: ¿Se remedian automáticamente algunos desvíos?
- Q4: ¿Se audita 100% de infraestructura?

METRICS (M):

- M1: % infraestructura bajo validación automática
- M2: # desvíos detectados/mes
- M3: % desvíos remediados automáticamente
- M4: MTTR remediación manual de desvío (horas)
- M5: % cobertura CIS benchmark compliance

PRAGMATIC EVALUATION:

- P (Predictive): 89 → Detecta configuración insegura
- R (Relevant): 90 → Alineado a seguridad operacional
- A (Actionable): 91 → Acción automática o manual clara
- G (Genuine): 87 → Datos de 70% orgs
- M (Meaningful): 88 → Impacto prevención directo
- A (Accurate): 90 → Medible en config management
- T (Timely): 92 → Real-time monitoring
- I (Independent): 88 → Independiente (puede ser standalone)
- C (Cost): 85 → Bajo costo (IaC, tools open-source)

PRAGMATIC SCORE: 89/100 ✓ EXCELENTE

D2: Publicar Datos Riesgo Artefactos [DM2.2] - ~55% orgs

GOAL (G): Comunicar riesgo de artefactos desplegados a operaciones

QUESTIONS (Q):

- Q1: ¿Se genera SBOM (Software Bill of Materials)?
- Q2: ¿Se publica análisis de riesgo (CVSS, EPSS)?
- Q3: ¿Se rastrean vulnerabilidades en runtime?
- Q4: ¿Qué % de equipos Ops accesa este data?

METRICS (M):

- M1: # aplicaciones con SBOM publicado (target 100%)
- M2: % con riesgo score por build
- M3: # vuln 0-day detectadas en runtime
- M4: MTTD vuln en runtime vs publicada (horas)
- M5: % equipos Ops con acceso a risk dashboard

PRAGMATIC EVALUATION:

- P (Predictive): 75 → Predice riesgo en runtime
- R (Relevant): 80 → Relevante a decisión ops
- A (Actionable): 82 → Lleva a decisión deploy/rollback
- G (Genuine): 72 → Datos en 55% orgs (todavía emergente)
- M (Meaningful): 78 → Impacto en decisiones operacionales
- A (Accurate): 75 → SBOM accuracy varía
- T (Timely): 85 → Disponible pre-deployment
- I (Independent): 70 → Depende de SAST/SCA upstream
- C (Cost): 68 → Herramientas SBOM son nuevas

PRAGMATIC SCORE: 76/100 ✓ ACCEPTABLE (Emergente)

PARTE IV: MAPEO COMPLETO BSIMM15 A GQM + PRAGMATIC

4.1 Tabla Resumen: 128 Actividades BSIMM15

#	Actividad BSIMM	Observación	Goal GQM	PRAGMATIC Score
1	CMVM1.1: IR Interface	91.7%	Detectar responder incidentes	87/100
2	SM1.4: Checkpoints Seguridad	90.1%	Formalizar control pipeline	89/100
3	CR1.4: Code Review Tools	87.6%	Automatizar SAST	91/100
4	AA1.1: Threat Modeling	86%	Identificar amenazas arquitectura	81/100
5	ST1.1: Dynamic Testing (DAST)	75%	Validar runtime security	81/100
6	ST2.1: Penetration Testing	~60%	Validar seguridad manual	77/100
7	DM1.1: Infrastructure Automation	~70%	Automatizar config validation	89/100
8	DM2.2: Publish Risk Data	~55%	Comunicar riesgo artefactos	76/100
...	... (120 más)	...	...	...

4.2 Escala de Madurez GQM Aplicada a BSIMM

L0 (Inexistente): 0-15% orgs practican (emerging, no estándar)
L1 (Iniciado): 15-40% orgs practican (ad-hoc)
L2 (Establecido): 40-65% orgs practican (common practice)
L3 (Operativo): 65-80% orgs practican (maturing)
L4 (Gestionado): 80-95% orgs practican (mature)
L5 (Optimizado): >95% orgs practican (best practice)

PARTE V: MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

(Ver documento 2: "Matriz de Evaluación PRAGMATIC Completa" para tabla detallada)

5.1 Consolidado Top 20 Métricas BSIMM

Rank	Actividad	Observación	P	R	A	G	M	A	T	I	C	Score	Recomendación
---	---	---	---	---	---	---	---	---	---	---	---	---	---
1	CMVM1.1 IR	91.7%	85	95	90	92	88	87	80	75	85	87	✓ Adoptar
2	SM1.4 Checkpoints	90.1%	93	96	94	90	92	91	93	70	88	89	✓ Adoptar
3	CR1.4 SAST Tools	87.6%	94	96	92	94	91	93	91	85	82	91	✓ Adoptar

4	AA1.1 Threat Model	86%	88 87 85 84 83 80 75 70 72 81	✓ Adoptar
5	ST1.1 DAST	75%	82 85 86 83 80 84 78 72 75 81	✓ Adoptar
6	ST2.1 Pentest	60%	85 88 87 82 86 75 60 65 60 77	⚠ Evaluar ROI
7	DM1.1 Infra Auto	70%	89 90 91 87 88 90 92 88 85 89	✓ Adoptar
8	DM2.2 Risk Data	55%	75 80 82 72 78 75 85 70 68 76	⚠ Implementar
9	CR1.3 Architecture Review	72%	82 85 80 78 81 75 70 68 65 76	⚠ Evaluar
10	CMVM2.2 Track Exceptions	71%	88 87 85 84 86 88 89 75 72 83	✓ Adoptar
11	PC2.2 Enforce Policy	70%	82 88 85 80 83 82 80 68 75 80	✓ Adoptar
12	EM2.1 Training Program	68%	75 90 88 76 85 70 60 55 80 76	⚠ Mejorar
13	SG1.2 Security Champions	64%	70 85 82 72 80 65 70 60 75 72	⚠ Evaluar
14	CMVM3.1 Event Alerting	62%	85 82 88 80 84 87 85 72 70 81	✓ Adoptar
15	CMVM3.3 Crisis Simulation	45%	75 88 70 68 75 60 50 58 55 66	⚠ Necesario pero bajo
16	AA2.1 Business Context	50%	70 82 75 65 76 60 65 62 60 68	⚠ Bajo ROI
17	SG2.1 DevSecOps	48%	80 88 85 75 82 80 80 70 75 79	⚠ Emergente
18	ST3.3 Continuous Testing	42%	85 85 85 70 82 85 88 75 65 80	⚠ Emergente
19	CMVM1.2 Metrics Collection	55%	82 88 80 75 84 85 75 70 72 79	✓ Adoptar
20	EM1.3 Metrics Dashboard	58%	88 92 88 80 90 85 85 72 78 84	✓ Adoptar

PARTE VI: RECOMENDACIONES ESTRATÉGICAS

6.1 Métricas de Adopción Inmediata (PRAGMATIC ≥ 85)

Prioridad 1 - Adoptar YA:

- CMVM1.1: IR Interface (87)
- SM1.4: Checkpoints (89)
- CR1.4: SAST Tools (91)
- DM1.1: Infra Automation (89)
- EM1.3: Metrics Dashboard (84)

Valor: Cubren 80%+ cobertura en 121 orgs + altísimo PRAGMATIC

6.2 Métricas de Evaluación (PRAGMATIC 70-84)

Prioridad 2 - Evaluar:

- AA1.1: Threat Modeling (81) - Subjetivo pero valuable
- ST1.1: DAST (81) - Complementa SAST
- ST2.1: Pentesting (77) - Alto costo, evaluar ROI
- DM2.2: Risk Data (76) - Emergente, adoptar para futuro

6.3 Métricas de Baja Adopción (PRAGMATIC < 70 O Observación < 50%)

Prioridad 3 - Monitor o Descontinuar:

- CMVM3.3: Crisis Simulation (66) - Bajo PRAGMATIC, pero importante
- AA2.1: Business Context (68) - Bajo ROI
- CMVM1.2: Metrics Collection (79) - Depende CMVM1.1

PARTE VII: GQM+ ADAPTADO PARA ESPAÑA (NIS2, ENS)

7.1 Meta Nacional España 2026

GOAL NACIONAL: "Madurez ciberseguridad software en 70+ puntos por índice NIS2 antes oct 2026"

QUESTIONS:

- Q1: ¿Cuántas apps españolas implementan SM1.4?
- Q2: ¿Cuál es MTDD promedio en orgs ES?
- Q3: ¿% cobertura SAST en sector crítico ES?

METRICS:

- M1: % apps críticas ES bajo SM1.4 (meta 90%+)
- M2: MTDD promedio ES vs media global (meta <12h)
- M3: PRAGMATIC score promedio ES vs EU (meta >85)

CONCLUSIÓN: TRAZABILIDAD ASEGURADA

Este marco **GQM + PRAGMATIC** aplicado a BSIMM15:

- ✓ **Trazabilidad completa:** Objetivo nacional → Preguntas operacionales → Métricas técnicas
- ✓ **Rigor metodológico:** 9 criterios PRAGMATIC evalúan utilidad práctica de cada métrica
- ✓ **Datos reales:** Basado en 121 organizaciones globales y 15 años BSIMM
- ✓ **Accionable:** Cada métrica lleva a decisión/inversión clara
- ✓ **Priorizable:** Score PRAGMATIC indica qué adoptar primero

Próximo Documento: Matriz de Evaluación PRAGMATIC Completa (todas 128 actividades)

FIN DEL MARCO INTEGRATIVO